ChatGPT

Drupal Field UI & Entity List RCE (CVE-2026-108097 & CVE-2026-108099)

1. Quick facts

- **Short title:** Drupal Field UI & Entity List RCE
- **Start date:** 2026-10-14
- **Category:** Zero-day vulnerability
- **Severity:** Critical, CVSS 9.8【29†L132-L140】
- **Who/what affected:** Drupal websites using supported Drupal 10.x and 11.x branches (an estimated ~151,000 sites, 28.5% of those reporting)【29†L55-L58】
- **Attacker:** Unattributed (no known exploit or attacker identified)【14†L53-L60】
- **CVE IDs:** CVE-2026-108097, CVE-2026-108099
- **Current status:** Patched. Drupal core was updated (to 10.6.19, 11.3.19, 11.4.10, etc.) and the Entity List module updated to 3.0.10. No confirmed exploitation in the wild as of 2026-11-10【14†L53-L60】.

2. One-paragraph summary

Two critical remote-code-execution flaws in Drupal (in its Field UI core module and Entity List add-on) were patched on 2026-10-14【11†L20-L28】【19†L20-L28】. An attacker could run code on a Drupal server if certain combinations of modules were installed. The flaws required no login in at least one attack path【24†L42-L45】. Administrators were urged to apply the security updates immediately. No active attacks were reported, but rapid exploits were warned【14†L53-L60】.

3. What exactly happened

Drupal, an open-source website platform, disclosed two critical security bugs in mid-October 2026. These bugs were remote code execution (RCE) vulnerabilities: one in Drupal core's **Field UI** component and one in the **Entity List** contributed module【11†L41-L44】【19†L40-L47】. *Remote code execution (RCE)* means an attacker can make the website's server run arbitrary code from a distance【24†L37-L44】. In this case, the vulnerability lay in code that only runs when certain field configuration features are used.

On its own, Drupal core did not expose the bug – it was only reachable through other modules or custom code. In other words, a specific chain of features had to be present. Security researchers found that when these modules were installed together, they opened "serious attack paths" to the Field UI code【24†L42-L45】. Crucially, at least one exploit route required no login (it was *unauthenticated*)【24†L42-L45】. That means a visitor could trigger the flaw without any account on the site.

Drupal's security team and researchers published an advisory on 2026-10-14【24†L35-L43】. They described the flaw and released patches immediately【11†L63-L72】【19†L53-L56】. The team gave it a

high risk score (19/25, “Critical”)【11†L25-L30】 and warned administrators to update quickly. Until patches were applied, they suggested uninstalling the Field UI module as a temporary workaround【24†L106-L110】.

In the days after release, cybersecurity outlets covered the news and reiterated the urgency. For example, SecurityWeek noted on 2026-10-19 that Drupal had issued fixes for the two critical RCE bugs【14†L30-L38】【14†L53-L60】. No one had publicly exploited the flaws yet, but analysts warned that automated attacks could appear soon if sites stayed unpatched【14†L53-L60】【24†L69-L77】. By early November 2026, the consensus was that site owners needed to patch immediately but there were no reports of actual compromises.

4. Timeline

- **2026-10-12:** Drupal Security Team issues a public service announcement scheduling a critical security release for 14 October【20†L79-L87】.
- **2026-10-14:** Security advisories SA-CORE-2026-014 and SA-CONTRIB-2026-218 are published. These disclose CVE-2026-108097 (Field UI RCE) and CVE-2026-108099 (Entity List RCE) and provide fixes【11†L20-L28】【19†L20-L28】.
- **2026-10-19:** SecurityWeek (via OffSec) publishes an analysis noting the vulnerabilities and available patches【14†L30-L38】【14†L53-L60】. They warn that at least one exploit path needs no authentication and advise updating Drupal core and modules immediately.
- **2026-11-10:** No new reports of active exploitation. All supported Drupal 10.x/11.x and Entity List sites are expected to have applied updates【14†L53-L60】.

5. How the attack worked

Imagine a Drupal website with certain features installed. *Contributed modules* are add-on plugins built by the community (beyond Drupal’s core code). The Field UI vulnerability was hidden in the code that manages content fields in the admin interface. By itself it wasn’t reachable, but some contributed modules could route web requests to that code.

Here’s a simplified attack chain: 1. **Attacker crafts a malicious request.** They might include special input (like a long, encoded string) targeting a web endpoint exposed by a contributed module. 2. **Website receives the request.** The contributed module passes this input into Drupal’s Field UI or Entity List code path. 3. **Triggering the flaw.** The malicious input exploits a logic bug in the Field UI/Entity List code. Because of the bug, Drupal ends up executing part of that input as code on the server. 4. **Remote code execution.** The server runs the attacker’s code. Now the attacker can do anything permitted by the webserver account (for example, read or write data on the site).

In these specific cases, at least one known exploit required no login (it was *unauthenticated*)【24†L42-L45】, meaning any site visitor could trigger it. Another way to think of it: a visitor sends what looks like a normal request (maybe through a site form or URL), but that request contains hidden payload. When the site processes it via the vulnerable module and core code, the attacker’s instructions run as if they were a valid script on the server.

Definitions: Remote Code Execution (RCE) means an attacker can make the server run commands from afar. A *module* is a plugin that extends a website's features. *Unauthenticated* means no password or login is needed for the attack to work. In short, the vulnerability let attackers "remotely execute" code through normal-looking web requests.

6. Impact

No specific breaches have been confirmed in connection with these bugs. However, the potential impact was high. Researchers estimated that about **151,000 Drupal sites** (28.5% of reporting sites) were running vulnerable versions before the fix【29†L55-L58】. These sites spanned government, business and other organizations. If an attacker had exploited the RCE flaws, they could have fully compromised a site: defacing pages, stealing database contents, installing malware, or otherwise taking control.

The vulnerabilities were rated *critical* because successful exploitation would allow full system compromise【11†L25-L30】. To date (Nov 2026), there is no public evidence that any of these Drupal sites were hacked using these bugs【14†L53-L60】. However, the fact that the flaws required no authentication in some paths meant the risk was considered urgent.

7. How it was fixed / what people were told to do

Drupal provided patched software and instructions in its advisories. Site administrators were told to **update Drupal core** to the following versions: for Drupal 10.6.x sites, upgrade to 10.6.19; for 11.3.x sites, upgrade to 11.3.19; for 11.4.x sites, upgrade to 11.4.10【11†L63-L72】. They were also told to **update the Entity List module** to version 3.0.10【19†L53-L56】. (Earlier versions of Drupal 10/11 are end-of-life and have no official fixes.)

As an interim measure, the advisory suggested *uninstalling* the core Field UI module (called `field_ui` in the system)【24†L106-L110】. Removing that module prevented the vulnerable code path from running until sites could apply updates. Drupal also noted that its "Drupal Steward" virtual patching service would block some attacks, but it was not guaranteed to cover every exploit path【11†L54-L59】.

Beyond these steps, general advice was to **backup the site**, apply the updates immediately, and test that everything still works after patching. No additional configuration changes or workarounds were needed once the updates were applied. All major Drupal hosting and distribution platforms also released updated packages.

8. Key lessons

- **Update promptly:** Even well-known platforms like Drupal can have critical bugs. Apply security updates as soon as they are available.
- **Minimize modules:** Third-party modules can introduce attack paths into core code. Install only needed modules and keep them up to date.
- **Virtual patching helps, but isn't enough:** Services like Drupal Steward can block some exploits, but they may not cover new attack chains. Full updates are the best protection.
- **Advance notice helps defenders:** Drupal's announcement (12 Oct) before the actual patch (14 Oct) gave admins time to prepare. Advance warnings are valuable.

- **No panic without evidence:** There were no confirmed exploits reported, so rushing to patch after disclosure (rather than assuming breaches occurred) was prudent.

9. Glossary

- **Remote code execution (RCE):** A security flaw that lets an attacker make a system run programs or commands of the attacker's choice.
- **Vulnerability:** A software bug that can be exploited to do something harmful.
- **Exploit:** A technique or code that takes advantage of a vulnerability.
- **Drupal core:** The main Drupal software (the official codebase); contrasted with add-on modules.
- **Contributed module:** A community-developed plugin for Drupal that adds features (not part of Drupal core).
- **Unauthenticated:** Action that can be done without logging in or having an account.
- **Patch:** A software update that fixes bugs or security flaws.
- **CVE:** "Common Vulnerabilities and Exposures," a standardized ID used to name a known security bug.

10. Sources

- [S1] **Drupal Security Advisory (SA-CORE-2026-014)** – *Drupal.org* – https://www.drupal.org/sa-core-2026-014 – *Official/Primary* – 2026-10-14 – Official advisory for CVE-2026-108097; describes the Field UI RCE and provides patched versions.
- [S2] **Drupal Security Advisory (SA-CONTRIB-2026-218)** – *Drupal.org* – https://www.drupal.org/sa-contrib-2026-218 – *Official/Primary* – 2026-10-14 – Official advisory for CVE-2026-108099; describes the Entity List RCE and provides the fixed version (3.0.10).
- [S3] **Drupal Security Team Sets Critical Core Release for 14 October** – *The DropTimes* – https://www.thedroptimes.com/72811/drupal-critical-security-release-october-14 – *News* – 2026-10-13 – Reports the Drupal PSA announcing a 14 Oct 2026 security release and summarizes the planned fixes.
- [S4] **Drupal Warns of Fast Exploitation Risk for Critical Core RCE Flaw** – *SecurityWeek (via OffSeq)* – https://radar.offseq.com/threat/drupal-warns-of-fast-exploitation-risk-for-critical-core-rce-flaw-947779ec8094d2b2 – *News* – 2026-10-19 – Article summarizing the Drupal RCE advisories, noting the CVEs, required patches, and lack of current exploitation【14†L53-L60】.
- [S5] **Drupal Warns Critical RCE Flaw Could Let Unauthenticated Attackers Compromise Websites** – *GBHackers (blog)* – https://gbhackers.com/drupal-warns-critical-rce-flaw/ – *News* – 2026-10-19 – Explains CVE-2026-108097 and the Field UI flaw; quotes the advisory's key points and patch instructions【24†L85-L93】【24†L106-L110】.
- [S6] **Drupal Field UI RCE (CVE-2026-108097) Analysis** – *Aviatrix Threat Research Center* – https://aviatrix.ai/threat-research-center/drupal-field-ui-rce-cve-2026-108097/ – *Researcher* – 2026-10 (Oct 2026) – Detailed analysis of CVE-2026-108097 and CVE-2026-108099. Provides executive summary, affected site estimates (151k sites) and patch info【29†L50-L58】【29†L132-L140】.
- [S7] **CVE-2026-98432: Linux TCP flaw rated 9.8, no Ubuntu or RHEL fix yet** – *Falcon Internet Blog* – https://www.falconinternet.com/blog/cve-2026-98432-linux-kernel-tcp-use-after-free-mptcp-ubuntu-rhel – *News* – 2026-10-30 – Describes the Linux CVE-2026-98432 timeline (patch and CVE publication dates). Cited to note that CVE-2026-98432 was published on 2026-10-15, outside the Black October window【40†L89-L97】.

11. Verification notes

- The Linux kernel vulnerability **CVE-2026-98432** was fixed/published on 2026-10-15【40†L89-L97】 (with patches noted Oct 30), which is after 2026-10-22. Therefore it falls outside the 17–22 Oct window. The query instructions said to replace it with the Drupal CVE-2026-108097/108099 event.
- Drupal's official advisories (SA-CORE-2026-014 and SA-CONTRIB-2026-218) were published on **2026-10-14**【11†L20-L28】【19†L20-L28】. The user's prompt mentioned "17 Oct 2026" but the facts show the release was on 14 Oct.
- No conflicts in severity or facts were found between sources. All sources agree the flaws are critical RCE (CVSS 9.8) and that patches were released the same day as disclosure.
- No primary government advisories (like CISA) were found for these specific CVEs. We relied on Drupal security advisories and security news outlets.
- The Aviatrix analysis (source [S6]) provided the 151,000 site figure. Other sources did not confirm site counts. We include it as it is a researched estimate.
- The OffSeq/SecurityWeek analysis and GBHackers articles agree that **no known exploitation** was reported by late Oct 2026【14†L53-L60】【24†L69-L77】. We report this as "no active exploitation" (unconfirmed).
- All key URLs were successfully opened and used. No key pages were inaccessible.